



Indian Health Service

Division of Information Security

Standard Operating Procedure for Wireless Network Security Standards

DIS-SOP-09-36

Version 2.2

February 2013

CONTROLLED UNCLASSIFIED INFORMATION (CUI)

Controlled with Standard Dissemination

This information is subject to safeguarding measures that reduce the risks of unauthorized or inadvertent disclosure. Dissemination is permitted to the extent that it would further the execution of a lawful or official purpose.

Record of Changes

Version	Date	Name	Description	Section
1.0	05/31/04	DIS	Final	All sections
1.1	12/31/08	DIS	Added additional requirement for scanning unauthorized WAPs	Sec 5
1.2	09/31/09	DIS	Overall update	All sections
2.0	11/01/11	P&P Team	Applied SOP template; added additional checklist item; changed WLAN scanning frequency; added two wireless scanning tools; changed ITAC Form to ITAC System; added procedure for disabling wireless card in Windows 7	All sections
2.1	12/19/12	P&P Team	Added Contact section; changed scanning frequency from 18 months to annually; added least privilege requirement; updated scanning tools in Appendix A	All sections
2.2	8/21/14	P&P Team	Removed procedure for XP; applied new introduction matter; updated wireless scanning section (removed reference to PTT service and VisiWave); minor language corrections throughout	Sections 1; 2.1
2.3	3/1/16	PSA Team	Updated review schedule. Updated color scheme. Added document name to header.	All

Approval

This Standard Operating Procedure (SOP) has been approved for distribution and implementation. These new procedures are effective immediately and will be enforced. Representatives of management will be authorized to conduct periodic quality checks and audits to assure compliance with these procedures.

Requests for corrections or changes to any procedures should be sent to the IHS Chief Information Officer (CIO). Exceptions or exemptions to any of these procedures must be submitted in writing to the IHS CIO for approval or disapproval.

Approved by:

/ Howard Hays /

2/1/13

Howard Hays, MD, MSPH
CAPT, U.S. Public Health Service
Chief Information Officer, IHS (Acting)

Date

Date of last review:

January 23, 2015

Reviewed by:

/ Steven Miller /

Steven Miller
Commander, U.S. Public Health Service
Supervisory IT Specialist, IHS

Contents

1. Introduction	1
1.1 Purpose and Scope.....	1
1.2 Contact Information.....	3
2. Standards for Wireless Network Security	4
2.1 Requirements.....	4
2.2 Recommendations	6
3. Guidelines for Implementing Wireless Networks at IHS	8
4. Inappropriate Use.....	9
5. Checklist	10
6. Glossary.....	11
7. Appendix: Wireless Scanning Tools.....	12

1. Introduction

The Indian Health Service (IHS) is responsible for implementing and administering an information security program to protect the agency's information resources. The procedures in this document are designed to protect IHS technology resources and data by mitigating information security threats, improving incident response, and reducing interference among systems.

Wireless network devices offer a simple, convenient, and inexpensive way to extend network accessibility by reducing the requirements of physical infrastructure. Wireless networking eliminates wired connections on portable devices and makes it possible for laptop and handheld users to travel beyond traditional network boundaries (for example, between buildings) without losing network connectivity.

However, in addition to the risks associated with any wired network, wireless technology introduces several unique vulnerabilities. Because wireless signals are radio transmissions, the proliferation of wireless appliances at IHS can lead to increased radio frequency interference (RFI) among medical devices. Furthermore, the signals can be intercepted by other radio receiving devices, including those outside the intended service area. If data transmissions are inadequately encrypted, the intercepted data can be read and understood in a matter of seconds. That means any data transmission sent through the wireless network is at risk, including patient data, user names and passwords, financial data, and other sensitive information. Advances in wireless signaling technology may increase transmission distances, further exacerbating the problem of unauthorized reception.

Because wireless transmissions can circumvent traditional perimeter firewalls, existing protections established to prevent unauthorized access are ineffective. Websites that identify open access points ("hot spots") that malicious users can use to access a network are becoming more common. If the IHS wireless network is improperly implemented, it can enable an unauthenticated user to get an IHS Internet Protocol (IP) address with all the benefits of an authenticated network user. Using one of these trusted IP addresses, a malicious user could attack IHS or any outside network that is connected to IHS.

This SOP establishes the procedure for the secure deployment and use of wireless network technology.

1.1 Purpose and Scope

This IHS Standard Operating Procedure (SOP) establishes wireless network security standards and procedures for IHS, compliant with all applicable federal laws and regulations. This procedure is, in large part, based on the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-153, Guidelines for Securing Wireless Local Area Networks (WLANs). This SOP

applies to all organizations or persons that collect, process, or maintain federally owned information or information systems, either directly or on behalf of IHS.

- This procedure supersedes SOP 06-36, Wireless Network Security Standards, but does not supersede any other applicable law or higher-level agency directive or policy guidance.
- The content of and compliance with this procedure shall be incorporated into applicable contract language, memoranda of agreement, or other agreements.
- This SOP pertains to all individuals using IHS systems, whether federal or non-federal.
- Areas must use this SOP or create a more restrictive SOP, but cannot use one that is less restrictive or less comprehensive, or does not comply with this document, departmental guidelines, IHS policies, or federal regulation.
- This procedure will be reviewed every three years to ensure that it is current and will expire three years from the date of its approval.

This SOP applies to all administrative management offices such as IHS Headquarters, Area Offices and service units, and all IHS-funded or directly supported health facilities and locations.

The term *facilities* includes all Indian Health urban locations where healthcare is provided or managed and all IHS or Tribally owned or operated hospitals, clinics, or any other locations where healthcare services are provided, managed, or otherwise supported.

- Facilities managed by Tribes or Tribal organizations whose network services IHS provides must follow this SOP in accordance with their contracts or compacts. IHS recommends all facilities operated by Tribe follow this SOP regardless of a given facility's network service provider.
- Contractors' and partners' facilities must follow this SOP in accordance with their interconnection security agreements with IHS.

For the purpose of this document, the term *IHS* includes any of the facilities described above.

1.2 Contact Information

If you have any questions or comments regarding this document, please contact the Office of Information Technology (OIT) Help Desk:

Phone: 888-830-7280

Web: <http://www.ihs.gov/helpdesk>

Email: support@ihs.gov

2. Standards for Wireless Network Security

All IHS federal employees, contractors, and third-party organizations must adhere to the following requirements and recommendations when they use wireless local area networks (WLANs) on any IHS IT system.

2.1 Requirements

These standards outline appropriate use of the IEEE 802.11 WLANs for IHS. The requirements are based on the IEEE 802.11 family of standards and do not incorporate any proprietary vendor security controls.

- WLAN products must comply with IEEE 802.11-2007.

Standard Configuration

- Wireless endpoint communications must be disengaged while they are physically connected to the IHS enterprise wired network. Some laptop computers have a wireless switch on the side or the front that can be used to disable and enable wireless functionality. The wireless switches usually have an image of a wireless antenna on them. The images vary by manufacturer, but they are usually similar to the examples shown in Figure 1.

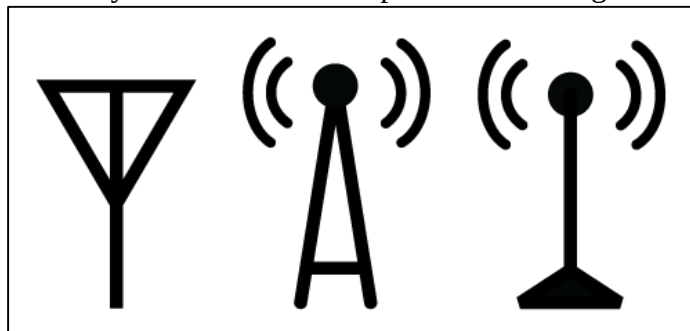


Figure 1: Examples of Wireless Antenna Images

If the computer doesn't have a wireless switch, follow the steps in the procedures below to disable the wireless network connection in Windows 7.

NOTE: Windows XP is no longer supported by Microsoft and should not be used at IHS. Windows 8 has not yet been formally authorized by IHS.

Windows 7

1. On the **Start** menu, click **Control Panel**.
2. Click **Network and Internet**.
3. Click **Network and Sharing Center**.
4. Click **Change Network Adapter Settings**.

5. Right-click the wireless network connection that you want to disable, and then click **Disable**, as shown in Figure 2.

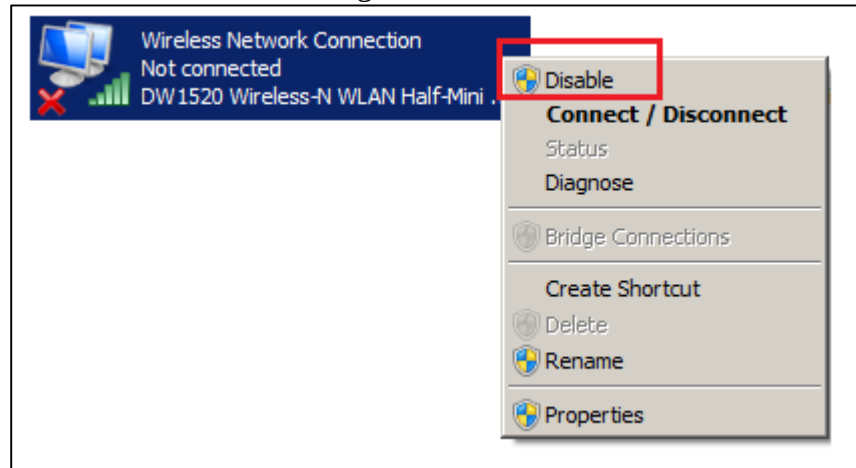


Figure 2: Windows 7 Wireless Network Connection Menu

- WLANs configured for public or open access are untrusted networks and must be segmented from the internal IHS network. A demilitarized zone (DMZ) must be placed between the WLAN and its wired distribution system, and a compliant Virtual Private Network (VPN) must be in place if a facility supports public users/open access.
- IHS password requirements and the warning banner procedure must be applied to all WLAN components. IHS password requirements are located in section 9 of the [IHS General User Security Handbook](#). The IHS warning banner procedure is located in section 5.2 of the [IHS Technical and Managerial Security Handbook](#).
- Designated personnel, such as the local ISSO, must scan WLANs annually or when major changes are made in order to identify and remove any unauthorized wireless access points. The WLAN's entire coverage area must be scanned.
- Several free scanning tools are available for WLAN scanning. Section 7, Appendix: Wireless Scanning Tools contains information about some of the many available wireless scanning tools. WLAN coverage areas that use a wireless intrusion detection system do not have to be scanned.
- Data in transit from authorized users on a WLAN to authorized users on a wired LAN must be filtered through an appropriate filtering device (for example, a firewall).
- WLAN traffic destined for the wired local area network must implement the principle of least privilege requirements (for example, specific IP addresses, protocols, ports, and hosts) to reduce the risk of unauthorized access.
- Maintain an inventory of all access points (APs) and assign static IP addresses to the APs. APs should be contained within enclosures or in physically secure locations to reduce the risk of unauthorized physical tampering or unauthorized physical access.

- If Simple Network Management Protocol (SNMP) is turned on for management purposes, change SNMP community strings from their manufacturer default to unique and difficult-to-guess strings.
- WLANs that are not configured for open/public access must implement IEEE.
- Implement 802.1X access control to reduce the risk of access from unauthorized WLAN devices, and provide authentication using a Federal Information Processing Standards (FIPS)-140-validated and Wi-Fi Protected Access 2 (WPA2)-certified Extensible Authentication Protocol (EAP) to verify authorized WLAN devices and/or users.
- Encryption for data that traverses a WLAN must use Advanced Encryption Standard (AES) algorithms that are validated under the National Institute of Standards and Technology (NIST) Cryptographic Module Validation Program¹ as meeting requirements of FIPS 140-2, at a minimum Overall Level 1.
- WLAN products must be Wi-Fi Alliance, WPA2- certified.
- WLAN traffic must be logically segmented from wired network traffic by use of a Virtual Local Area Network (VLAN), when possible.

2.2 Recommendations

The following recommendations will further enhance the security of a wireless network. Where feasible, consider adopting these recommendations in addition to the requirements listed above.

- Register the static IP addresses for wireless access points in the Domain Name System (DNS), and use IHS naming conventions.
- Use MAC-based authentication by allowing only registered MAC addresses to have access to the AP. It is possible to spoof MAC addresses, but MAC-based authentication provides another layer to the security of an otherwise insecure data transfer medium.
- Use multiple levels of authentication and security. Recommendations include using Remote Authentication Dial-In User Service (RADIUS) authentication or public key infrastructure (PKI).
- Ensure the wireless device satisfies any existing RFI standards.
- Use an encryption protocol between any two wireless devices. At a minimum, the wireless access point must require WPA2 or connect through the IHS-managed VPN concentrator. All encryption modules must be certified under FIPS 140-2.

¹ The Cryptographic Module Validation Program is a joint effort between NIST and the Communications Security Establishment Canada, that validates cryptographic modules to FIPS. Refer to <http://csrc.nist.gov/groups/STM/cmvp/index.html>.

- Avoid broadcasting to areas not intended for service. Locate APs centrally within the intended area of service, and avoid placing APs near windows or against the outside walls of buildings.
- Designated personnel should scan for unauthorized wireless APs (WAPs) annually or when major changes are made. If a rogue WAP is found, the local ISSO must be notified to investigate. (CAUTION: If a scan is conducted in a hospital, the scanner could find devices that appear to be wireless access points but are actually medical devices. Automatically disconnecting such a device is dangerous and may lead to malfunction of medical devices.)
- Designated personnel should check annually to ensure that the organization's WLAN client devices and APs have configurations that are at all times compliant with this SOP.
- Disable broadcasting the Extended Service Set Identification/Service Set Identification (ESSID/SSID).
- Change all default ESSID/SSIDs from their default vendor settings to unique names. The ESSID/SSID can be accessed from within wireless products' web-based or Windows-based configuration utilities. Common examples of predefined ESSID/SSIDs are simple names like "wireless," "netgear," "linksys," or "default." An ESSID/SSID can be changed at any time, as long as the change is also made on all wireless clients. The following are best practices:
 - Don't use information such as name, address, organization, or other types of personal information as part of the ESSID/SSID.
 - Don't use any of your Windows or Internet website passwords.
 - Don't tempt would-be intruders by using tantalizing network names like "HEALTHCARE-BOX" or "TOP-SECRET."
 - Do pick an ESSID/SSID that contains both letters and numbers.
 - Do choose a name as long or nearly as long as the maximum length allowed.
 - Do consider changing your ESSID/SSID every few months.

3. Guidelines for Implementing Wireless Networks at IHS

Follow these guidelines when implementing or using wireless networks.

- To enable wireless access for a user, the user's supervisor must request the access through the [Information Technology Access Control \(ITAC\)](#) system.
- Local IT staff will configure the client access securely, including encryption and layered authentication.
- Local IT staff will maintain a database or equivalent system to track wireless hardware allocation and user access.
- ISSOs and local IT staff should provide additional training on the risks associated with wireless networks before they grant wireless privileges.
- IT staff will periodically audit connections and connection attempts and report rogue hardware and security violations to the Area ISSO.

4. Inappropriate Use

The following list describes inappropriate use of wireless networks.

- Unauthenticated or unencrypted wireless communications are not permitted on the IHS network.
- The use of wireless keyboards is not allowed on IHS networks or equipment.
- Wireless communications must not be used to bypass IHS security controls such as Websense and firewalls.
- Users are required to comply with the [General User Security Handbook SOP06-11a](#), which prohibits the insecure storage or transmission of sensitive data. Users may not send, store, or process patient information without appropriate security safeguards, as per HIPAA privacy and security requirements.
- Wireless devices are not to be used within an environment where they may disrupt other systems (for example, telephone, healthcare equipment, and radio/microwave transmitters).
- Per-session dynamic RC4 keys, including but not limited to dynamic wired equivalent privacy (WEP), temporal key integrity protocol (TKIP), and WPA, must not be used to secure WLAN communications.
- The use of static or pre-shared keys is not permitted.
- Wireless connections must not be used to administer the WLAN or LAN.
- Ad-hoc connections between endpoint wireless devices without a centralized infrastructure are prohibited.

5. Checklist

Use the following checklist to ensure that wireless devices and networks are secure.

- ☐ Wireless device is installed in a properly secured, adequately monitored location.
- ☐ Device IP address and supported IP address range is separate and unique from the wired IP ranges; that is, there is no possibility of any wired device using the WLAN IP addresses.
- ☐ Device configured with a static IP address.
- ☐ Device administration password changed from the default to a unique password conforming to the IHS password policy.
- ☐ Device SSID changed from the default to a unique, unpublished SSID.
- ☐ Device configured not to broadcast the SSID.
- ☐ Device configured to automatically disable its wireless network capability when physically plugged in through a port into the IHS enterprise wired network.
- ☐ If SNMP is active, SNMP community strings changed from manufacturer default to unique, unpublished strings.
- ☐ Device configured for WPA2 encryption. This is the minimum encryption requirement.
- ☐ Device WLAN isolated by a firewall with the principle of least privilege requirements (for example, specific IP addresses, protocols, ports).
- ☐ Inventory maintained and regularly updated with wireless devices, configurations, and authorized users.
- ☐ Device signal area and frequency are on non-overlapping channels and do not interfere with any other devices, wireless or otherwise (such as medical devices).
- ☐ After they are connected to the device, users are authenticated to an IHS central source, such as Active Directory.
- ☐ DNS entries conform to IHS naming conventions.
- ☐ Personnel are designated to periodically scan WLANs or monitor a wireless intrusion detection system (IDS).
- ☐ Wireless users have been trained on the risks associated with using a wireless device.

6. Glossary

See the [online glossary](#) on the IHS Security website.

7. Appendix: Wireless Scanning Tools

Name: VisiWave Wireless Sniffer

Type: Windows

Availability: Freeware, <http://www.visiwave.com/>

Description: VisiWave Site Survey is a complete 802.11a/b/g/n site surveying solution. It collects survey data using a standard wireless adapter while walking around the survey area clicking on a floor plan image, using a GPS receiver to track your location, or using a customized navigation device.

Name: AirSnort Wireless Sniffer

Type: UNIX

Availability: Freeware, <http://airsnort.shmoo.com/>

Description: AirSnort is a freeware wireless LAN sniffer tool that recovers encryption keys. AirSnort operates by passively monitoring transmissions, computing the encryption key when enough packets have been gathered.

Name: Kismet Wireless Sniffer

Type: UNIX

Availability: Freeware, <http://www.kismetwireless.net/>

Description: Kismet is an 802.11b wireless network sniffer. It is capable of sniffing using almost any wireless card supported in Linux.

Name: Netstumbler Wireless Sniffer

Type: Windows

Availability: Freeware, <http://www.netstumbler.com>

Description: Netstumbler is an 802.11b tool that listens for available networks and records data about that access point. A version is available for the Pocket PC.

Name: WEPCrack WEP encryption cracker

Type: UNIX

Availability: Freeware, <http://sourceforge.net/projects/wepcrack/>

Description: WEPCrack is a tool that cracks 802.11 WEP encryption keys using the latest discovered weakness of RC4 key scheduling.

Name: WaveStumbler Wireless Network Mapper

Type: UNIX

Availability: Freeware, <http://www.cqure.net/wp/tools/other/wavestumbler/>

Description: WaveStumbler is a freeware console-based 802.11 network mapper for Linux. It reports the basic wireless network characteristics including channel, WEP, ESSID, and MAC.